Vulnerability Management

Assessment Methodologies, Scoring Systems, and Scanning Tools

Vulnerability Management is the proactive process of identifying, classifying, and remediating weaknesses in digital infrastructure. This module introduces the concept of **vulnerabilities** as inherent flaws in software or hardware that attackers can exploit. It details the methodologies of **Vulnerability Scanning**, differentiating between **Authenticated vs. Unauthenticated** and **Internal vs. External** assessments.
We examine the industry-standard identification and scoring systems: **CVE (Common Vulnerabilities and Exposures)** and **CVSS (Common Vulnerability Scoring System)**. Additionally, the content provides a technical overview of prominent scanning tools such as **Nessus**, **Qualys**, and **Nexpose**, with a specific focus on the open-source **OpenVAS** platform. Mastering these fundamentals allows security professionals to prioritize risks and implement critical **Patches** to safeguard organizational assets.

This **documentation** and **learning** approach is strongly inspired by the structured, hands-on content provided by **TryHackMe**, which significantly contributed to practical understanding of "Vulnerability Scanner Overview" concepts.

DOCUMENTED BY
Kaustubh Ghosalkar aka "WEIRDO"

LINKEDIN GITHUB

1. Understanding Vulnerabilities and Patching

A **Vulnerability** is a weakness or flaw in a system's software or hardware that can be leveraged by an unauthorized party to compromise the device or network.

- **Patching:** The process of applying a fix or update to a software program or system to remediate a discovered vulnerability.
- **The Hunting Process:** Unlike physical leaks, digital vulnerabilities are often invisible until hunted through specialized security audits.

2. Vulnerability Scanning Methodologies

Organizations utilize automated scanners to efficiently inspect vast networks for known security flaws. These scans are categorized based on access levels and network location.

Authenticated vs. Unauthenticated Scans

Scan Type	Requirements	Depth of Visibility
Authenticated	Requires valid **Host Credentials**.	High; scans configurations and internal applications.
Unauthenticated	Requires only the **IP Address**.	Low; identifies flaws exposed to external attackers.

Internal vs. External Scans

- **Internal Scans:** Conducted from **inside the network** to identify vulnerabilities exposed to an attacker who has already gained initial entry.
- **External Scans:** Conducted from **outside the network** to identify vulnerabilities in public-facing assets like web servers.

3. Industry-Standard Tools

Several automated tools exist to facilitate vulnerability management, each suited for different organizational scales.

- **Nessus:** Developed by Tenable; a widely used proprietary tool with extensive scanning features for enterprises.
- **Qualys:** A cloud-based platform that provides continuous monitoring and automated alerts without on-premises hardware costs.
- **Nexpose:** Developed by Rapid7; specializes in asset discovery and provides risk scores based on asset value and impact.
- **OpenVAS:** An open-source assessment system developed by Greenbone Security, offering a comprehensive suite for smaller organizations.

WEIRDO

4. Identification and Scoring: CVE and CVSS

To manage thousands of vulnerabilities, the security industry uses standardized naming and scoring protocols.

CVE (Common Vulnerabilities and Exposures)

Developed by the **MITRE Corporation**, a CVE is a unique identifier assigned to a specific vulnerability (e.g., **CVE-2024-9374**).

- **Prefix:** "CVE".
- **Year:** The year the vulnerability was discovered.
- **ID:** Unique arbitrary digits.

CVSS (Common Vulnerability Scoring System)

A numerical score (0 to 10) representing the severity of a vulnerability.

CVSS Score Range	Severity Level
0.0 - 3.9	**Low**
4.0 - 6.9	**Medium**
7.0 - 8.9	**High**
9.0 - 10.0	**Critical**

5. OpenVAS Management

OpenVAS is often deployed via **Docker** containers to simplify dependency management and ensure environment stability.

Command Section: Docker Management

Task	Command
Install Docker	sudo apt install docker.io
Run OpenVAS	sudo docker run -d -p 443:443 --name openvas immauss/openvas
Start Container	docker start openvas

The Scanning Workflow

1. **Access:** Log in via https://127.0.0.1.
2. **Create Task:** Navigate to **Scans > Tasks** and select **New Task**.
3. **Define Target:** Enter the **Target Name** and **IP Address**.
4. **Execute:** Click the **Play** button under "Actions" to initiate the scan.
5. **Review:** Analyze the results labeled as **Done** to view vulnerability counts and details.

WEIRDO

6. Practical Task (Task 6)

I researched the provided vulnerability scan report for the server on the network and **found** several key security indicators. Below is how **I solved** the assessment:

- **Work Done: I practiced** starting the OpenVAS environment using the docker start openvas command. **I researched** the existing report placed on the desktop to identify the most urgent threats.
- **Vulnerability Analysis: I found** a single high-severity vulnerability within the scan results. **I practiced** analyzing the technical details and **founded** that the **CVSS score** for this specific vulnerability was **7.5**.
- **Remediation Solution: I researched** the "Solution" section of the OpenVAS report to determine the best course of action. **I solved** the query by identifying that the suggested solution was to **Upgrade the software/service** to the latest patched version.
- **Result: I practiced** interpreting automated reports to prioritize high-risk assets, ensuring a threat-informed defense posture for the firm.

Conclusion and Cheatsheet

Conclusion

Vulnerability Management transitions security from a reactive to a proactive state. By utilizing standardized frameworks like **CVE** and **CVSS**, organizations can objectively measure risk and prioritize **Patching**. Whether deploying enterprise solutions like **Nessus** or open-source tools like **OpenVAS**, the goal remains to minimize the attack surface. Effective vulnerability management requires consistent scanning—both **Authenticated** for depth and **Unauthenticated** for perimeter visibility—to maintain compliance and security integrity.

Fast Revision Cheatsheet

- **Vulnerability:** A system weakness.
- **Patch:** A fix for a vulnerability.
- **Authenticated Scan:** Uses credentials; finds internal flaws.
- **Unauthenticated Scan:** No credentials; finds external flaws.
- **MITRE:** The organization that manages **CVEs**.
- **CVSS Score 10:** Represents a **Critical** vulnerability.
- **CVSS Score 5.3:** Represents a **Medium** vulnerability.
- **OpenVAS:** Leading open-source vulnerability scanner.
- **HTTPS Port 443:** The default port to access the OpenVAS web interface.
- **CVE-YYYY-XXXX:** Standard format for vulnerability identification.